

SACI: Explainable Graph-Based Attack Surface Visibility Scoring Using SIEM Telemetry and Threat Intelligence

Ismet Arslan

Abstract—This study presents SACI v2, a scope-bounded framework for measuring security information and event management visibility through evidence relationships among assets, log sources, detection controls, Wazuh rules, MITRE ATT&CK techniques, and cyber-threat-intelligence objects. The method combines Criticality-Weighted Log Coverage (CWLC), Control/Alert Coverage (CAC), in-scope ATT&CK Detection Coverage (MDC), CTI flag closure (CTIC), and Telemetry Freshness (TF) using active-metric weight normalization. In the final-v2 publication snapshot of a six-asset Wazuh-MISP laboratory, 12/12 expected asset-log-source pairs, 25/25 enabled controls, 13/13 in-scope techniques, and 8/8 CTI flags across two IOC records were closed; all five components and the composite SACI score were 100. The published graph contains 97 declared nodes and 171 edge rows with observed=1; an integrity audit additionally identified 165 unique relationship triples, two undeclared endpoints, and six isolated nodes. A separately maintained 20-scenario historical suite exhibited directionally expected score changes under component loss and recovery. The results should be interpreted as evidence closure within a predefined laboratory scope, not as a guarantee of operational security. The released code and derived tables support arithmetic and graph audit, whereas absent upstream inputs limit full independent replay.

Keywords—SACI, SIEM, Wazuh, evidence graph, MITRE ATT&CK, cyber threat intelligence, visibility scoring, auditability

I. INTRODUCTION

Modern security operations centers (SOCs) continuously collect endpoint, identity, network, and application telemetry to detect malicious behavior and prioritize response. The presence of a SIEM, however, does not by itself demonstrate that critical assets are monitored by expected sources or that relevant adversary techniques have observable evidence.

The growth of enterprise attack surfaces makes this distinction increasingly important. Cloud services, remote-access platforms, firewalls, identity providers, and third-party integrations produce fragmented evidence. High alert volume may coexist with stale telemetry, disabled controls, or disconnected technique mappings that create operational blind spots.

This study asks: how can heterogeneous SIEM telemetry and threat context be transformed into a visibility score with traceable provenance and an explicitly bounded scope? SACI joins assets, log sources, detection controls, rules, ATT&CK techniques, and CTI objects in a typed evidence graph.

SACI is not a model of risk, attack prevention, or probability of detection. It deterministically reports which expected relationships close within a declared evidence

universe, how each component contributes to the score, and which data-integrity exceptions constrain interpretation.

The contributions are fourfold: (i) a typed graph schema for SIEM-CTI evidence; (ii) an implemented score combining CWLC, CAC, MDC, CTIC, and TF with active-weight renormalization for N/A metrics; (iii) a final-v2 publication snapshot plus a separately maintained 20-scenario historical sensitivity suite; and (iv) an auditable research companion publishing raw outputs, the scorer, graph builder, and integrity checks [13].

II. RELATED WORK

A. SIEM Telemetry and Continuous Monitoring

Continuous monitoring requires security status to be evaluated through evidence observed over time rather than isolated checks [4]. NIST CSF 2.0 likewise connects governance and measurement to organizational context [5]. SACI applies this principle to asset-log-source, control-rule, and technique relationships.

Wazuh provides endpoint monitoring, rule-based detection, and ATT&CK-related rule metadata [2]. A technique identifier in a rule, however, does not prove that the corresponding asset and log source were observed or that the detection is externally effective. SACI therefore distinguishes configuration presence from observed coverage relationships.

B. MITRE ATT&CK and Threat Intelligence

MITRE ATT&CK provides a structured cross-platform knowledge base of adversary tactics and techniques [1]. Despite broad adoption, operationalizing ATT&CK coverage and interpreting assessment results remain open challenges [6]. SACI's MDC component counts only a predefined in-scope technique set.

STIX and TAXII support machine-readable representation and exchange of indicators and related cyber-threat objects [3], [11]. CTI models facilitate contextual enrichment, but the link between external context and internal telemetry still requires validation [10]. SACI exposes this link through four implemented flags.

C. Graph-Based Cybersecurity Assessment

Cybersecurity knowledge graphs combine multi-source asset, event, vulnerability, and intelligence data for provenance and decision support [8]. Closed-world assumptions and limited laboratory data can nevertheless make it difficult to distinguish a truly absent relation from missing evidence [9].

ATT&CK-based rating frameworks summarize assessment results through technique coverage [7]. Advanced persistent-threat studies also show that multistage behavior cannot be reduced to one indicator [12]. SACI complements this literature by measuring scope-bounded SIEM evidence closure rather than detection efficacy.

III. PROPOSED MODEL

SACI contains five logical layers: scope and asset inventory, telemetry/detection evidence, ATT&CK-CTI context, typed graph fusion, and active-weight-normalized scoring. Fig. 1 summarizes how final-v2 expectations and observations become scores, integrity findings, and publishable artifacts.

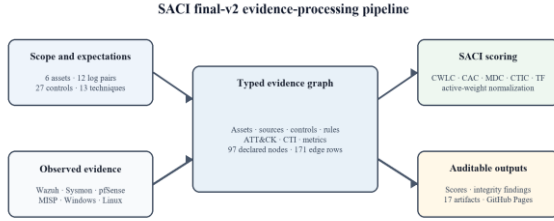


Fig. 1. SACI final-v2 evidence-processing and publication pipeline.

A. Graph Schema

The graph is $G=(V,E)$. V contains asset, log-source, detection-control, Wazuh-rule, ATT&CK-technique, typed-CTI-object, platform, integration, score-metric, and reason-code nodes. E contains directed, typed evidence rows identified by source and target.

Final-v2 instantiates 17 relationship labels: alerted_in, collected_by, contains, contains_ioc, contributes_to, converted_to_alert, detects_technique, emits, mapped_to, maps_to, matches_ioc, produces_rule, protected_by, queries, triggers_integration, uses, and uses_log_source. observed=1 denotes a row closed in the generated evidence table; observed=0 denotes a declared but unclosed row.

Asset node: an in-scope system identifier, hostname, and criticality value.

Log-source/control node: an expected telemetry source and enabled detection control supported by that evidence.

Rule/technique node: a Wazuh rule and its in-scope ATT&CK technique mapping.

CTI/platform/metric node: an IOC, MISP-Wazuh integration element, or computed SACI component.

Integrity evidence: observation state, unique triples, undeclared endpoints, isolated nodes, and conditional reason-code outputs are evaluated together.

B. Visibility Metrics

Component scores lie in $[0,100]$. For the applicable metric set M^* , the composite score is divided by the sum of active weights; N/A metrics are not assigned zero but are removed from both numerator and denominator.

$$\text{SACI} = (\sum_{m \in M^*} w_m S_m) / (\sum_{m \in M^*} w_m)$$

All final-v2 metrics are active, with CWLC=0.30, CAC=0.25, MDC=0.20, CTIC=0.15, and TF=0.10. The weights sum to 1.00; they are design choices rather than probabilities.

$$\text{CWLC} = L_a = \sum_s (w_{as} o_{as}) / \sum_s w_{as};$$

$\text{CWLC} = 100 \cdot \sum_a (c_a L_a) / \sum_a c_a$, where o_{as} is observation state, w_{as} source weight, and c_a asset criticality.

$\text{CAC} = 100 \cdot \sum_c (w_c e_c s_c) / \sum_c (w_c e_c)$, where e_c is enabled state, s_c is observation state, and w_c is control weight; disabled legacy controls are excluded from the denominator.

$\text{MDC} = 100 \cdot \sum_t z_t / |T_{\text{scope}}|$, where z_t is technique coverage. The implementation is count-based within the declared scope and does not use the published priority field as a score weight.

$\text{CTIC} = 100 \cdot \sum_i (\text{lookup}_i + \text{hit}_i + \text{alert}_i + \text{map}_i) / (4|I|)$. The four fields measure flag closure; because lookup_executed is initialized from expected_lookup, it is not independent proof of query execution or a causal event chain.

TF: for the globally newest event age Δ , the score is 100 ($\Delta \leq 60$ min), 80 ($60 < \Delta \leq 1440$ min), 50 (an older event), or 0 (no event). TF is not per-source freshness.

C. Explainability Layer

The explainability layer presents component scores together with the asset, source, control, rule, technique, and CTI relationships that produced them. A reason-code mechanism can emit deterministic explanations for unclosed components, preventing the result from being reduced to one composite number.

An empty final-v2 reason-code output means that no scripted score gap was emitted in that run; it does not imply an absent explanation mechanism or the absence of data-integrity limitations. No LLM generates the numerical score; natural-language generation may only summarize verified tabular and graph evidence.

D. Scoring Procedure

The pipeline declares the expected scope, constructs derived observation tables, computes five components, builds the typed graph, and publishes the results with integrity checks. The final-v2 scorer normalizes active metrics; the graph builder derives traceable relationship rows from the same coverage tables.

Step 1: Define the evaluation scope with six assets and their expected asset-log-source pairs.

Step 2: Construct observation/flag tables for log sources, enabled controls, ATT&CK techniques, and two synthetic IOCs.

Step 3: Compute CWLC, CAC, MDC, CTIC, and TF using the implemented equations.

Step 4: Generate node and relationship rows while retaining observation state and evidence-provenance fields.

Step 5: Audit endpoint references, unique triples, isolated nodes, mapping consistency, and reason-code output.

Step 6: Renormalize active weights and publish SACI with the machine-readable research companion.

IV. CONTROLLED LABORATORY AND DATA PIPELINE

Final-v2 was produced in an authorized, controlled Wazuh-MISP laboratory. The scope contains six assets: DC01, WSIEM, CTI01, FW01-PFSENSE, WS01, and uhost. Sources include Windows Security, Sysmon, PowerShell, ossec, MISP API/enrichment, pfSense syslog, and Linux authlog, syslog, and process telemetry.

WSIEM/Wazuh: central collection, rule evaluation, alert generation, and MISP-integration evidence.

DC01 and WS01: logon, process, DNS, and discovery telemetry from Windows Security, Sysmon, and PowerShell. **uhost and FW01-PFSENSE:** Linux authentication/process evidence plus network and IOC-related pfSense syslog events.

CTI01: synthetic MISP/IOC validation records for `cti-test.example.com` and `203.0.113.66`.

Telemetry universe: 12 expected and observed asset-log-source pairs across six assets.

Detection universe: 27 control rows, of which 25 are enabled, and 13 declared in-scope ATT&CK techniques.

A. Telemetry and Scenario Generation

An authorized attack runner produces synthetic behavior for Windows, Linux, pfSense, and CTI paths; Wazuh rules and mapping tables convert these observations into expected control/technique records. This design exercises the computation without publishing real user or production secrets.

final-v2 is the primary publication snapshot. A separate S0-S18 historical suite contains 20 deterministic sensitivity scenarios spanning SIEM deployment, full closure, and critical/noncritical telemetry, CTI, freshness, and rule loss. Historical S8's 95/173 graph is not combined with final-v2's 97/171 graph.

B. Data Processing and Publication

The `log_source_status`, `control_coverage`, `mitre_coverage`, and `ctic_coverage` tables provide derived evidence to the scorer. `saci_score_v2.py` computes components; `saci_graph_v2.py` emits node/edge files and CYJS/Mermaid representations. Because both derive from the same tables, the graph is a traceable representation rather than an independent validation dataset.

The release bundles score and graph outputs with the runner, reason-code files, summary, source code, and validation manifest. Raw artifacts are published without in-place repair; the portal adds only explanatory and interactive views [13].

V. FINAL RESULTS AND DISCUSSION

In final-v2, 12/12 asset-log pairs are observed across six assets. Of 27 control rows, C003 and C004 remain disabled legacy controls; all 25 enabled controls are seen. All 13 in-scope techniques have covered=1, and all four implemented flags are 1 for each of two IOC records.

CWLC: 100.0 (weight 0.30; 6 assets and 12/12 expected log pairs).

CAC: 100.0 (weight 0.25; 25/25 enabled controls; active weight 23.3/23.3).

MDC: 100.0 (weight 0.20; 13/13 declared in-scope techniques).

CTIC: 100.0 (weight 0.15; 2 IOC records x 4 flags = 8/8).

TF: 100 (weight 0.10; the globally newest event was in the ≤60-minute tier at scoring time).

SACI:

$[0.30(100)+0.25(100)+0.20(100)+0.15(100)+0.10(100)]/1.00 = 100.0$.

SACI=100 indicates that component expectations closed under the implemented rules within the declared final-v2

evidence universe. It does not imply a secure environment, detection of every attack, coverage of the complete Enterprise ATT&CK knowledge base, or measurement of false-positive/negative rates.

The graph audit found 97 declared nodes, 171 edge rows with observed=1, 165 unique source-relationship-target triples, and 17 relationship labels. LOGSOURCE:Wazuh and MITRE:T1071.001 are undeclared endpoints; six declared nodes are isolated. Rule 110203 maps to T1071.001 in the control table but T1071.004 in the CTIC table. Thus, 171/171 row closure is not perfect referential integrity.

The historical sensitivity suite produced directionally expected changes: SACI rose from 0.00 in S0 to 94.00 after S6 CTI integration and 100.00 in historical S8 closure. Critical DC01 Sysmon loss yielded 78.53 in S7A versus 92.52 for noncritical WS01 loss in S7B; CTI loss yielded 92.50 in S12/S13 and freshness decay 95.00 in S15. S17 recovery returned to 100.00.

A. Validity and Limitations

In construct-validity terms, SACI measures predefined evidence closure, not detection probability, prevention effectiveness, false-alarm rates, MTTD, or residual risk. Internal validity depends on expected rule/technique fields in the runner and scorer; some records can retain expected labels independently of runner return codes. The CTIC lookup flag is likewise expectation-derived.

External validity is limited to one six-asset Wazuh-MISP laboratory, two synthetic IOCs, and 13 selected techniques. TF uses the global newest event, so one fresh source can mask stale sources, and the exact scorer timestamp is not published. Because upstream `/opt/saci-lab/data` inputs, raw live-log snapshots, and complete environment automation are absent, the bundle supports arithmetic/graph audit rather than full end-to-end replay.

VI. IMPLEMENTATION AND AUDITABILITY

The implementation comprises an authorized scenario runner, deterministic Python scorer, and graph builder. The final-v2 appendix publishes 17 machine-readable files: coverage CSVs, score JSON/CSV, node/edge tables, CYJS/Mermaid graphs, reason-code outputs, and source code. Embedded SHA-256 checks verify release identity.

The interactive GitHub Pages portal presents methodology, architecture, final-v2 evidence tables, a scenario-selectable graph, and an artifact map [13]. It labels final-v2 and historical scenarios separately, visualizes undeclared endpoints as explicit placeholders, and keeps the interpretation boundary visible.

VII. AUDIT PROTOCOL AND OPERATIONAL INTERPRETATION

A. Publication Layers and Audit Chain

The audit protocol separates three evidence layers: the declared evaluation scope, observation tables derived from that scope, and the published score/graph artifacts. The first layer fixes asset, source, control, technique, and IOC denominators; the second records observed, enabled, covered, and implementation flags; and the third carries

component scores, relationship rows, and integrity findings. An independent reviewer can recompute numerators and denominators from the CSV and JSON files, reproduce the reduction of 171 edge rows to 165 unique triples, and compare undeclared endpoints against the node table. SHA-256 checks bind the identity of the publication package, but they do not by themselves establish the authenticity of upstream telemetry or prove that the run completed fully. Likewise, an empty reason-code output only means that the implemented rules emitted no explanation. SACI therefore treats deterministic package audit and complete experimental reproduction as distinct assurance levels.

B. Decision Semantics of the Scores

Each evaluation should be read as a five-component score vector together with the active metric set, weights, and scope identifier, rather than as the composite SACI value alone. Active-weight normalization prevents an N/A component from being treated as an artificial zero; however, runs with different active metric sets have different denominators and are not directly comparable. The same requirement applies to versioning the scope, control states, and technique list. A documented policy may exclude disabled legacy controls from the CAC denominator, whereas an enabled but unseen control must remain a gap. Asset criticality also explains the designed asymmetry between S7A and S7B; that difference is not a probabilistic risk estimate. Under these conditions, SACI can serve as a publication gate, an evidence-completeness audit, or a fixed-scope longitudinal indicator. Ranking products, teams, or organizations across heterogeneous scopes would be methodologically unsupported without additional calibration and external validation.

C. Sensitivity and Failure Semantics

The 20 scenarios in S0-S18 are deterministic perturbation and recovery experiments, not independent statistical observations. They test progression from an empty baseline through CTI integration and full closure, the unequal effect of critical and noncritical telemetry loss, removal of CTI flags, and decay across the freshness tiers. S7A falling below S7B confirms the intended criticality weighting; S12 and S13 converging at 92.50 confirms the same CTIC loss; and S15 decreasing to 95.00 reflects the expected TF contribution. These experiments show that the scorer responds to its inputs and implements the intended weight ordering. They do not estimate causal effect size or predictive performance because repeated trials, distributional assumptions, confidence intervals, and independent field samples are absent. Statistical validation would require a separate preregistered study with replicated runs, multiple laboratories, and observed operational outcomes.

D. Productionization Principles

For production use, the pipeline should fail closed on unsuccessful runs, and every observation should be bound to a run identifier, an actual alert or event identifier, a source timestamp, and a file digest. Freshness should be computed per source rather than from the globally newest event; schema checks should reject missing or unexpected columns; and the graph builder should be able to invalidate

a run under an explicit integrity policy, rather than merely report undeclared endpoints. The T1071.001/T1071.004 discrepancy for rule 110203 should be reconciled in one versioned mapping source. Scope, weight, and threshold configurations should accompany every result, while the portal should remain a derived view of the same immutable artifacts. Continuous-integration tests can enforce score-graph consistency, unique relationship keys, isolated-node policy, and reason-code coverage. External validity should ultimately be tested by independent teams applying the protocol across different SIEM products, network topologies, and operational sites.

VIII. CONCLUSION

SACI v2 demonstrates the feasibility of transforming a predefined SIEM-CTI evidence universe into a traceable graph and an active-weight-normalized visibility score. In final-v2, all five components score 100, arithmetically supported by 12/12 log pairs, 25/25 enabled controls, 13/13 in-scope techniques, and 8/8 CTI flags.

The result remains scope-bounded. Future work should require provenance based on actual alert identifiers and timestamps, exclude failed runner executions from scoring, reconcile the T1071.001/T1071.004 mapping, add per-source freshness, automate referential-integrity tests, and perform multisite external validation with complete environment and raw-data snapshots.

IX. DATA AND ARTIFACT AVAILABILITY

Final-v2 score, coverage, reason-code, graph, and source-code artifacts, together with the interactive research companion, are published through the SACI Final Evidence Portal [13].

REFERENCES

- [1] The MITRE Corporation, "Enterprise Matrix," MITRE ATT&CK. Accessed: Jun. 21, 2026. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>
- [2] Wazuh, "MITRE ATT&CK framework - Data analysis," Wazuh Documentation. Accessed: Jun. 21, 2026. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/ruleset/mitre.html>
- [3] OASIS Cyber Threat Intelligence TC, "STIX Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [4] K. Dempsey, N. Chawla, A. Johnson, R. Johnston, A. Jones, A. Orebaugh, M. Scholl, and K. Stine, "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations," NIST Special Publication 800-137, 2011.
- [5] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," NIST Cybersecurity White Paper, 2024.
- [6] B. Al-Sada, A. Sadighian, and G. Oligeri, "MITRE ATT&CK: State of the Art and Way Forward," arXiv:2308.14016, 2023.
- [7] H. Manocha, A. Srivastava, C. Verma, R. Gupta, and B. Bansal, "Security Assessment Rating Framework for Enterprises using MITRE ATT&CK Matrix," arXiv:2108.06559, 2021.
- [8] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, "A review of knowledge graph application scenarios in cyber security," arXiv:2204.04769, 2022.
- [9] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in Proc. IEEE Symposium on Security and Privacy, 2010, pp. 305-316.
- [10] V. Mavroeidis and S. Bromander, "Cyber threat intelligence model: An evaluation of taxonomies, sharing standards, and ontologies within cyber threat intelligence," in Proc. 2017 European Intelligence and Security Informatics Conference, 2017, pp. 91-98.
- [11] OASIS Cyber Threat Intelligence TC, "TAXII Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html>
- [12] M. Ussath, D. Jaeger, F. Cheng, and C. Meinel, "Advanced persistent threats: Behind the scenes," in Proc. 2016 Annual Conference on Information Science and Systems, 2016, pp. 181-186.
- [13] I. Arslan, "SACI Final Evidence Portal: final-v2 research artifact," 2026. [Online]. Available: <https://4rslanismet.github.io/saci-final-evidence/> Accessed: Jul. 11, 2026.